

Copenhagen Municipality Criticized in Supervision Case Regarding AULA

Date: 23-05-2024

Decision

Public Authorities

Criticism

Supervision / Self-Management Case

Processing Security

Children

Data Protection Officer (DPO)

Sensitive Information

Fundamental Principles

Risk Assessment and Impact Analysis

The Data Protection Agency has now made a decision in the sixth and final supervision case regarding the processing security in AULA, which the agency initiated in the autumn of 2021 concerning six selected municipalities. At the Data Protection Agency's contact committee meeting in May, the work on processing security in AULA formed the basis for discussions on risk assessments and impact analyses.

Journal Number: 2023-423-0005.

Summary

In December 2023, the Data Protection Agency made decisions in five out of six supervision cases initiated in the autumn of 2021 regarding the selected municipalities' processing of personal data in the IT system AULA. The supervisions focused on compliance with the data protection regulation's rules on processing security and impact analysis.

Copenhagen Municipality Criticized for Deficiencies in Impact Analysis

The Data Protection Agency has now made a decision in the supervision case involving Copenhagen Municipality, which is the sixth and final of these cases. The Data Protection Agency has expressed criticism, as the agency has assessed that the impact analysis does not meet all the minimum requirements for an impact analysis. The decision also contains some recommendations for the municipality's further work on the planned update of the impact analysis.

Regarding the municipality's risk assessment, the Data Protection Agency has recommended that Copenhagen Municipality, in their revised risk assessment concept, structure the information so that it becomes possible to compare the risk assessments before and after the implementation of the measures, and that the connection between the measures and the individual risks is clearly presented. The Data Protection Agency found that the municipality had not fully demonstrated that appropriate measures had been implemented to reduce all the risks identified by the municipality.

However, Copenhagen Municipality has worked seriously and purposefully to reduce the identified risks. In particular, the municipality has focused on reducing the risk that the use of UNI-login entails, according to the municipality's assessment.

The supervision case involving Copenhagen Municipality contains more elements than the other five supervision cases. The Data Protection Agency became aware of an internal supervision report from Copenhagen Municipality's data protection advisor, which among other things concerned the municipality's use of AULA's module "Secure File Sharing," based on a press mention in the spring of 2023. Therefore, in this case, the Data Protection Agency has examined the supervision report and requested the municipality to answer some questions.

Based on this, the Data Protection Agency has recommended in the decision that Copenhagen Municipality – possibly in dialogue with the other municipalities, KOMBIT, and KL – clarify the purpose of processing personal data in AULA in the municipality's impact analysis. The Data Protection Agency has further noted that it is relevant to clarify which document types "Secure File Sharing" in AULA is used for, and what types of personal data these document types typically contain.

Contact Committee Meeting with Regions and Municipalities

At the Data Protection Agency's contact committee meeting with the municipalities and regions in May 2024, the theme was the authorities' practical experiences with risk assessments and impact analyses. Here, the discussions were based on the AULA supervisions, where the Data Protection Agency had just examined six municipalities' risk assessments and impact analyses.

The Data Protection Agency had invited Esbjerg Municipality to the contact committee meeting to share their practical experiences with risk assessments and impact analyses regarding the processing of personal data in AULA. Esbjerg Municipality emphasized the importance of creating an overview through good records, which form the basis for further work on data protection. The municipality also stressed the significance of integrating technology (solutions/systems), processes (standards/workflows for use), and personnel (daily use) as a data controller to identify and reduce risks when a new system is implemented.

Esbjerg Municipality pointed out that having insight into employees' workflows and their practical use of IT tools is a prerequisite for the work. This knowledge makes it easier to conduct risk assessments in future decisions regarding the procurement and implementation of new systems and IT solutions in general.

Additionally, the Data Protection Agency had invited KOMBIT to discuss their further work and considerations following the Data Protection Agency's briefing on the decisions in the AULA supervisions. In their briefing, the Data Protection Agency had, among other things, encouraged the municipalities – possibly in collaboration with KL and KOMBIT – to consider preparing a joint impact analysis regarding the municipalities' processing of personal data in AULA. KOMBIT presented their considerations regarding a potential joint impact analysis, and several municipalities provided comments and suggestions at the meeting.

KOMBIT also discussed their compliance package, which contains a number of templates designed to assist municipalities with data protection. They are working to ensure that these templates become available internally to the relevant employees in the municipalities. At the meeting, the Data Protection Agency presented the template for conducting impact analyses for AI solutions, which the agency was at that time in the process of...

complete. Subsequently, the template, along with a more generic template for impact assessment, has been published on the Data Protection Agency's website. They can be found here.

1. Written supervision of the City of Copenhagen regarding the processing security in AULA

The City of Copenhagen is among the municipalities that the Data Protection Agency selected for supervision in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2]. The Data Protection Agency's supervision is a written oversight with a particular focus on the technical and organizational security measures that have been observed to comply with the requirement for an appropriate level of security for the processing activities in the IT system AULA. The supervision is a continuation of the Data Protection Agency's previous supervision of Kombit A/S (hereinafter KOMBIT) in December 2019, where the supervision during a site visit could ascertain that KOMBIT is not to be regarded as the data controller for AULA under Article 4, No. 7 of the General Data Protection Regulation. Therefore, the Data Protection Agency informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibilities and that KOMBIT provides the municipalities with all necessary materials and information in this regard. The Data Protection Agency expects that KOMBIT has informed the municipalities about this immediately after the site visit in December 2019.

2. Decision

After a sample review of KOMBIT's risk assessment materials and a review of the City of Copenhagen's risk assessment as well as the other materials submitted, the Data Protection Agency finds that the City of Copenhagen has demonstrated that it has identified the most significant risks that the municipality's processing of personal data in AULA poses to the data subjects. The City of Copenhagen appears to have documented how the municipality has assessed the risk to the data

subjects from the relevant processing activities, as well as how the municipality relates to KOMBIT's risk assessment. The City of Copenhagen seems to have worked very seriously and purposefully to reduce the identified risks. In this context, the City of Copenhagen is particularly noted to have worked on reducing the risk that the use of UNI-login, according to the municipality's assessment, entails. However, it is the Data Protection Agency's assessment that the City of Copenhagen has not fully demonstrated that the municipality has implemented appropriate measures to reduce all identified risks, including the risks outlined in the risk assessment materials from KOMBIT. The Data Protection Agency has noted that the City of Copenhagen is working on a revised risk assessment concept. Therefore, the Data Protection Agency recommends that the City of Copenhagen structures the information in the revised risk assessment concept in such a way that it is possible to compare the assessments of risks before and after the measures have been implemented, and that the relationship between measures and individual risks is clear. In this way, an overview can be created that can help ensure that all identified risks have been assessed and managed through the implementation of appropriate security measures. After reviewing the City of Copenhagen's impact assessment and the underlying risk assessment forms, the Data Protection Agency finds that the City of Copenhagen, regarding the timing of the preparation of their impact assessment, has acted in accordance with Article 35, Paragraph 1 of the General Data Protection Regulation. However, it is the Data Protection Agency's assessment that the City of Copenhagen has not conducted a sufficient impact assessment, cf. Article 35, Paragraph 1 of the General Data Protection Regulation, as the submitted impact assessment does not meet the minimum requirements set out in Article 35, Paragraph 7, letters a-d of the Regulation.

On this basis, the Data Protection Agency finds grounds to criticize that the City of Copenhagen's processing of personal data has not been carried out in accordance with Article 35, Paragraph 1 of the Regulation. Finally, the Data Protection Agency finds that the rollout of AULA to the daycare institutions has not resulted in such a change in the risk posed by the processing activities that the City of Copenhagen should have conducted a renewed review of the impact assessment in accordance with Article 35, Paragraph 11 of the General Data Protection Regulation. The Data Protection Agency has noted that the City of Copenhagen had planned an update of the impact assessment in the autumn of 2023 based on the municipality's new concept for risk assessments, including impact assessments. The Data Protection Agency recommends that the municipality, in this context, updates the information in the impact assessment so that it accurately reflects that AULA is also used in the municipality's daycare institutions. Furthermore, the Data Protection Agency recommends that the City of Copenhagen – possibly in dialogue with other municipalities, KOMBIT, and KL – clarifies the purpose of the processing of personal data in AULA in the municipality's impact assessment. In this context, it is also relevant to clarify in the impact assessment which document types Secure File Sharing is used for, and what types of personal data these document types typically contain.

3. Case presentation

The Data Protection Agency has, by letter dated October 15, 2021, announced the supervision of the City of Copenhagen. In this connection, the Data Protection Agency has requested the municipality to submit the following: The risk assessments that form the basis for the assessment of what security is considered appropriate for the processing of information about natural persons in "AULA," as well as a description of the general security models in the application. To the extent that impact assessments have been prepared, copies of all versions of these.

A review of considerations regarding the use of Article 25 of the Data Protection Regulation in connection with the acquisition and development of "AULA".

A review of authorization and access management models.

Copenhagen Municipality submitted a statement to the case along with a number of attachments on November 10, 2021.

The Data Protection Agency subsequently requested Copenhagen Municipality by email on July 7,

2022, to send copies of all previous versions of their impact assessment.

Copenhagen Municipality sent the municipality's impact assessments for AULA from 2020 and 2021, as well as a number of other security documents, which the municipality states should be seen as a supplement to the impact assessments, on August 10, 2022.

In this context, Copenhagen Municipality stated that the impact assessment for 2022 had not been prepared at that time.

Based on the statements from the six selected municipalities, the Data Protection Agency has chosen to limit the focus of the inspections to questions regarding risk assessment and impact assessment. It should be emphasized in this context that the Data Protection Agency has not, in connection with this inspection, taken a position on whether Copenhagen Municipality's processing of personal data in AULA is in accordance with Article 25 of the Data Protection Regulation regarding data protection by design and by default, or whether the municipality's authorization and access management models are in accordance with Article 32 of the Data Protection Regulation.

Based on media coverage regarding Copenhagen Municipality's use of AULA for storing sensitive child cases with notifications, investigations, notes, action plans, and well-being assessments, the Data Protection Agency on May 22, 2023, requested Copenhagen Municipality to send a copy of the internal audit report from the municipality's data protection advisor that was mentioned in the press.

The Data Protection Agency received the audit report on May 24, 2023.

Subsequently, on June 23 and August 31, 2023, the Data Protection Agency requested Copenhagen Municipality to answer a number of questions regarding the municipality's use of AULA.

Copenhagen Municipality then provided statements on August 16 and September 21, 2023.

The Data Protection Agency and Copenhagen Municipality discussed the agency's questions regarding the submitted impact assessments and the risk assessment forms that were sent as a supplement to the impact assessments by phone on January 26, February 21, and March 14, 2024. Additionally, Copenhagen Municipality responded to the Data Protection Agency's questions via emails on February 2 and February 29, 2024. Following the Data Protection Agency's request, Copenhagen Municipality also submitted additional material to the case on February 5, February 21, and March 11, 2024.

3.1. General Information on the Decision and Development of AULA

The Danish Municipalities' Association (hereinafter KL) states on their website that the municipal acquisition of AULA is part of the User Portal Initiative, which is a political initiative from 2013.[3] It further states that AULA aims to support communication and thereby collaboration regarding children's learning and well-being in a secure and user-friendly manner.

KL also states that all 98 municipalities in Denmark jointly participated in a common tender for a collaboration platform – the later AULA – for the school sector in 2016. AULA was put out to tender by the municipalities' IT community, KOMBIT A/S (hereinafter KOMBIT), at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and Business Consulting, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice.

KOMBIT provides information about AULA on the website aulainfo.dk. It appears from this that the majority of public schools began using AULA in 2019 and daycare services in the winter of 2020/2021.[4]

The Data Protection Agency assumes that the individual municipalities are independently responsible for their processing of personal data in AULA, and that KOMBIT, which is the municipalities' data processor, has entered into a data processing agreement with Netcompany, which is thus a sub-processor.[5]

3.2. Copenhagen Municipality's Comments

3.2.1. Risk Assessment

3.2.1.1. Material Received from Copenhagen Municipality

Copenhagen Municipality has stated that AULA has been implemented with an exemption, as AULA does not fully comply with the municipality's security regulations. In this connection, Copenhagen Municipality has stated that AULA is based on UNI-login services, and that the municipality cannot control access, as users can log in bypassing approved authentication processes.

Copenhagen Municipality has also stated that since 2014, the municipality has attempted to reduce

and eliminate the risks related to login and data delimitation. In this context, they have submitted a background note on the work with security in AULA in the Children and Youth Administration and a timeline from 2014 to 2020 regarding Copenhagen Municipality's efforts to address security challenges in AULA.

It appears from the attached recommendation regarding the extension of the exemption for user management of AULA that employee access via UNI-login would be phased out on March 31, 2022, when UNI-login changes with the transition from NemID to MitID in the first quarter of 2022. Thus, the municipality's employees will lose the ability to log in with private NemID. Furthermore, it is stated that Copenhagen Municipality has issued an instruction to their employees to use the municipality's own solution for access management, as the municipality can manage employees' rights through this solution.

Copenhagen Municipality has stated that a number of risk assessments regarding AULA have been prepared. In this context, the municipality has stated that they have been prepared based on to the identified risks in a serious manner. The analysis indicates that the supplier has recognized significant deficiencies that need to be addressed to ensure compliance with security standards.

3.2.1.4. Security Assessment by Copenhagen Municipality's Corporate IT

The risk assessment includes a security evaluation conducted by Copenhagen Municipality's Corporate IT. This evaluation serves as a foundation for understanding the security posture of the AULA system and highlights areas that require improvement. The findings from this assessment are crucial for the ongoing risk management process.

3.2.1.5. Access Control in PIT

The risk assessment also addresses access control measures within the Pædagogisk IT (PIT) framework. It emphasizes the importance of implementing robust access controls to safeguard sensitive data and ensure that only authorized personnel can access specific information within the AULA system.

3.2.1.6. Communication and Collaboration Modules

The assessment further examines the communication and collaboration modules within AULA. It identifies potential vulnerabilities and suggests enhancements to improve the security of these functionalities, ensuring that they meet the necessary compliance requirements.

3.2.1.7. Conclusion

In conclusion, the risk assessment conducted by Copenhagen Municipality provides a comprehensive overview of the security landscape surrounding the AULA system. It outlines necessary actions to mitigate identified risks and emphasizes the importance of adhering to established security protocols. The municipality's commitment to addressing these issues is evident in the outlined action plan and ongoing collaboration with relevant stakeholders.

actively addresses AULA's actual consequence level and risks for the registered individuals and their rights. It subsequently appears that the mitigating actions of the City of Copenhagen actively align with the supplier's assessment of risks, and that the municipality shares the described viewpoints.

In this context, it is noted that there are also a number of technical shortcomings in the system that the municipality's administration is unable to rectify. The City of Copenhagen has therefore reached out to KOMBIT, among other things, with proposals for better data protection in AULA's messaging module. The Data Protection Agency has received a copy of the municipality's communications to KOMBIT regarding AULA's messaging module.

Based on a sample review of the risk assessment material submitted by KOMBIT, which the City of Copenhagen has referred to in their risk assessment, the Data Protection Agency has determined that the attached material from KOMBIT generally states that a number of processing activities carried out in AULA involve a high risk for the registered individuals. Furthermore, the material indicates that it is expected/probable that a number of scenarios will occur, which involve consequences categorized as "devastating" or "very serious."

The Data Protection Agency can confirm that KOMBIT has generally identified high risks concerning

the following threats:

1. Lack of access control or errors in this
2. Mismanagement of personal data in the system/solution, carried out by an authorized user
3. Incorrect handling due to incorrect or missing implementation of data classification in the solution
4. Incorrect accesses due to unclear or lacking policies
5. Use of inadequately protected username and password

Regarding the messaging module in AULA, it is stated, for example, in KOMBIT's risk assessment that they have identified 10 threats, three of which are deemed most likely. The three threats are marked in red, and the Data Protection Agency understands from the material that KOMBIT assesses these as high risks.

One of the threats concerns user behavior that leads to mismanagement of personal data in the system, carried out by an authorized user through unintentional disclosure of personal data in the application. The consequence of loss of confidentiality is categorized as "devastating," and it is noted, among other things, that children may suffer significant reputational damage, which can lead to social losses. The likelihood is categorized as "expected," and it is noted in this context that it is anticipated that there will be cases where a user mistakenly sends a message containing personal data to one or more users, for example, by sending to a group.

Another threat concerns unintentional process errors that lead to incorrect handling due to incorrect or missing implementation of data classification in the solution. It is further described as a leak of sensitive data due to incorrect (too low) or missing data classification. The consequence of loss of confidentiality is categorized as "very serious." It is noted that the reason for this is that sensitive personal data (e.g., messages regarding a child's illness/health) can be accessed or altered by unauthorized individuals internally, and that registered individuals are exposed internally to unauthorized access. Furthermore, it is stated that registered individuals are exposed in a way that harms social relationships, both internally among colleagues/students. The likelihood is categorized as "expected." It is noted in this context that it is users who must classify data, and human errors are anticipated. As an example, it is stated that it is possible for a user to send a message containing sensitive personal data without marking it as "sensitive message," resulting in lower security.

The third threat concerns unintentional process errors where there are incorrect accesses due to unclear or lacking policies. The consequence of loss of confidentiality is categorized as "very serious." The material provides the same description of the consequence as for incorrect handling due to incorrect or missing implementation of data classification in the solution. The likelihood is categorized as "expected." It is noted in this context that all municipalities must assign rights to many users/groups, which is why errors must be expected. As an example, it is stated that a group may have members who no longer belong to the group and who have not been removed from the group.

The City of Copenhagen describes in a submitted background note regarding the work on security in AULA in the Children and Youth Administration that the municipality's risk assessment differs from KOMBIT's risk assessment, as KOMBIT assesses that AULA has strong functional separation and strong user authentication, and therefore KOMBIT assesses that data leaks as a result are unlikely.

The Data Protection Agency thus assumes based on this note that the City of Copenhagen, in addition to the risks identified in KOMBIT's risk assessments, has also identified high risks concerning unauthorized access to AULA and data due to insufficient user authentication and unauthorized access to data due to lack of or insufficient functional separation in system accesses.

3.2.1.4. UNI-login

It is stated in the aforementioned background note that in connection with the initiation of AULA, it was concluded in a legal prerequisite note for the User Portal Initiative that data in AULA did not have sensitive character, but that there were only a few confidential data, and that UNI-login was therefore sufficient. The City of Copenhagen subsequently states in their background note that the City of Copenhagen...

a) the checkbox.

2) BUF assesses that the current design of the messaging module does not sufficiently restrict access to sensitive information. This means that users may inadvertently send messages containing sensitive information without proper safeguards in place, increasing the risk of unauthorized access to such data.”

3.2.1.6. Conclusion

In conclusion, the document outlines the various security challenges associated with the use of UNI-login and the AULA messaging module. It emphasizes the need for stronger authentication measures and the implementation of organizational safeguards to protect sensitive data. The ongoing efforts by Københavns Kommune to address these issues through training and the development of new systems are also highlighted. The document serves as a comprehensive overview of the current state of security measures and the steps being taken to enhance data protection within the municipality.

dem.

BUF therefore proposes measures to protect against the incorrect transmission of sensitive information in the form of alerts, pop-up boxes, etc. However, this is outside BUF's scope of action, as the implementations must be technical. BUF has therefore contacted KOMBIT with these proposals for better protection.

To address this issue, BUF has implemented possible organizational measures in the form of guidelines and training of employees, which are maintained quarterly and as needed.

2) Sending messages with secure files results in secure files being attached as a file to the message. This means that data marked as sensitive is accessible to anyone who may have access to the message – even if they do not have the right to access sensitive data about the child. If a message containing sensitive data is sent incorrectly, the recipient can read all content. Secure files should be sent as a link to the secure file, which can only be accessed by users with rights. This will protect data if the file is sent to the wrong recipient.”

An update from April 2021 indicates that there is an ongoing process at KOMBIT regarding the first point to improve the messaging module so that users do not accidentally send sensitive information to the wrong recipients. Regarding the second point, it is stated that secure files are now sent as links, and thus the point/challenge is resolved.

3.2.1.6. Profiles in AULA

In the risk assessment section regarding profiles in AULA, there is a reference to KOMBIT's risk assessment concerning the threat "Insufficient rights management in AULA's profile module," which is considered to have immediate and clearly destructive consequences in terms of loss of confidentiality and serious consequences regarding integrity. The municipality refers in the section to point 3 of the action plan. In an update from April 2021, it is stated that processes for

correct assignment of user accesses and rights have been implemented, and that training and guidance are provided in this regard.

3.2.2. Consequence Analysis

Copenhagen Municipality has submitted two versions of their consequence analysis regarding the processing of personal data in AULA. The first consequence analysis is dated March 3, 2020, and the second consequence analysis is dated April 20, 2021. Copenhagen Municipality has stated that the latest consequence analysis has been updated in connection with the latest request for exemption from the municipality's IT security regulations.

Copenhagen Municipality has indicated that the consequence analysis is based on the municipality's then-current consequence analysis concept. Furthermore, Copenhagen Municipality has stated that there have been no updates to the consequence analysis since April 2021, as there have not been significant changes in the use of AULA, but that an update of the consequence analysis was planned for the fall of 2023 based on the municipality's new concept for risk assessments including consequence analyses.

Subsequently, Copenhagen Municipality has stated that no new consequence analysis has been conducted after the rollout of AULA in the municipality's daycare facilities in May 2021, and that this is an error. However, Copenhagen Municipality assesses that the consequence analysis from April 2021 is accurate except for the information regarding legal basis and target group, which should have been updated with relevant professional legislation and number of registered individuals. The municipality assesses that there is no difference in the use of AULA between daycare facilities and schools.

The consequence analysis contains an overall assessment and conclusion. It is stated in the latest version from April 2021 that the consequence analysis showed the following distribution of risks after measures were implemented: 7 items with low risk (58%), 5 items with medium risk (42%), and 0 items with high risk (0%). It is indicated that medium risks must not exceed 70%, and that all high risks must be eliminated. If these conditions are not met, the municipality's data protection advisor must be contacted for further advice.

In comparison, it is stated in the first version of the consequence analysis from March 2020 that the consequence analysis showed the following distribution of risks after measures were implemented: 8 items with low risk (67%), 2 items with medium risk (17%), and 2 items with high risk (17%).

The Data Protection Agency can, by comparing the two versions of the consequence analysis, ascertain that the two items that were originally assessed to pose a high risk after the implemented measures,

but which in the latest version are assessed to have been reduced to a medium risk are as follows:

Management of access and rights to the system (It must be possible to manage who has access to the system, including whether they are employees or external persons. It must be possible to create access profiles that correspond to the rights an employee should have to perform their work tasks, and which ensure functional separation between roles/task areas such as caseworker and control responsible.) Identification of physical persons via their personal data (Ensuring that information about the registered individuals can be anonymized or pseudonymized to the necessary extent) and Access to personal data (Ensuring that access to personal data in systems or in documents containing personal data is secured - thus limiting access, for example, through security features on documents that are stored/journalized.)

The section of the consequence analysis titled "1. Assessment of the objective conditions of the processing" contains the municipality's names of the processing processes and a the purpose of the processing is communication between school and home. Additionally, the section includes a statement of the legal basis in the Folkeskole Act for the processing activities, a description of the existing systems—both primary and secondary systems—that support the processing processes, the number of processors (employees in the municipality) and registered individuals (citizens), the total number of data streams, and the total number of personal data. It is also stated that the following types of personal data are processed: Addresses in general, CPR numbers, family relations, health information, personal information, secure files about students with sensitive information, personal messages, and photos.

Furthermore, the section indicates that information is processed about the following types of registered individuals: School students, employees, and parents/contact persons (citizens). Additionally, the following types of processing activities are specified: Anonymization, restriction, collection, registration, deletion, searching, use, and dissemination. The different types of processing activities are categorized into low, medium, and high risk. In relation to the specified processing activities, "dissemination" is registered under medium risk, while the other processing activities are registered under low risk.

It is also indicated in the section in a field about special conditions that there is no automatic processing, large-scale profiling, and that there are no special citizen considerations. Finally, the retention period is stated in the section along with the municipality's assessment regarding whether there is a requirement for a data processing agreement.

Section 2 of the impact assessment titled "Risk Score of Processing Processes, cf. Pactius Privacy" appears to be unfilled. The section contains two fields next to the headings probability and consequence. However, the fields are empty.

Following the section, it is stated that an impact assessment must be conducted based on objective conditions (1) and the derived risk score (2) and by considering inherent risks and risks after measures have been taken.

The impact assessment then contains an overview of the following 12 conditions that, according to the impact assessment, must be managed to ensure the rights and freedoms of individuals:

1. Management of access and rights to the system.
2. Encryption and other communicative security measures, integration requirements for other systems, and access via mobile/portable devices.

3. Identification of individuals via their personal data and access to personal data.
4. Opportunities for control/management supervision regarding access and use of the system.
5. Ensuring specific processing activities and their legal requirements.
6. Limitation/deletion/archiving of personal data.
7. Physical security.
8. Emergency management/damage control.
9. Management of consent declarations.
10. Rights of the registered individuals and compliance with the Public Access to Information Act.
11. Automated decisions.
12. Data processor.

For each condition, an assessment of the inherent risk (low, medium, or high) is made regarding the potential violation of individuals' rights and freedoms when the processing is carried out, and if security measures are not managed. The risk description briefly outlines what the risk is if the specific condition is not managed.

Additionally, one or more security measures that can be implemented are specified. For each of these security measures, it is indicated whether a technical and/or organizational measure has been implemented, or whether the security measure has been completely omitted. Reference numbers to the municipality's risk assessment are also provided.

In the impact assessment, it is stated that an assessment of the risk after the measure (small, medium, or high) has been made. In the latest version of the impact assessment received by the supervisory authority, it is briefly described what the risk is after the described security measures have been implemented. This is also the case concerning the two conditions mentioned above, where it is indicated in the latest version of the impact assessment that the risk has been reduced to medium from high in the first version of the impact assessment.

Regarding the condition of managing access and rights to the system, the following is noted:

"1) Due to a lack of management of authentication options, the user can log in with logins from other municipalities as well as unilgin. However, the user can no longer access sensitive personal data via private NemID. 2) Lack of functional separation allows access to all the user's identities (e.g., employee in Copenhagen, employee in Gentofte, parent) which have different rights across identities with one login. 3) User management occurs via Unilgin, which the municipality does not administer."

Regarding the condition of identifying individuals via their personal data and access to personal data, the following is noted:

"1) Challenges with authentication and functional separation may allow users to log in with non-approved authentication methods. However, sensitive information can no longer be accessed via NemID, which lowers the risk."

Finally, the impact assessment contains three columns under the heading "Help Columns." It is indicated that

if there is more than one primary system that supports the processing process, auxiliary columns are used to record the characteristics of the individual primary systems. It further states that if there is a difference in the security level of measures in the primary systems, information about technical and organizational measures is used (transferred) based on the system that provides the least security to some other columns in the impact analysis, after which these form the basis for the impact assessment. In the three columns, the following systems are included: KMD student (school), UNI-login, and KMD institution (daycare). It is indicated in relation to all three systems that they send data. No information is provided in the columns regarding the security level of the measures. The Data Protection Agency has understood that the assessments in the submitted risk assessment forms, which the City of Copenhagen has sent as a supplement to the impact analyses, are the basis for some of the information in the impact analyses. The two risk assessment forms contain a number of control questions, which are divided into the following themes: Physical security of location (perimeter security) and securing access points (servers, routers, etc.) Procedures and role/task distribution for

supporting technical security measures (access allocation, log review, etc.) The registered person's access to correction/update of registered information Mobile equipment and remote workplaces Supplier relationships Acquisition, development, and maintenance of systems Vulnerability management Encryption Logging and monitoring Downtime, backup, and disaster recovery Documentation

Communication security The form from 2020 contains 77 questions, and the form from 2021 contains 92 questions. In the form from 2020, there is a tab titled "Calculation Engine," where for each control question, columns have been filled out with, among other things, risk descriptions, an indication of threats, descriptions of vulnerabilities, an assessment of initial risk and (residual) risk, assessment of probability and consequence, an indication of whether it involves a possibility of loss of confidentiality, integrity, and/or availability, and suggestions for controls that reduce the risk. The risk assessment form from 2021 does not contain this tab. After comparing the reference numbers in the impact analyses with the numbers appearing in the risk assessment forms, the Data Protection Agency can, however, ascertain that the topics to which the respective reference numbers pertain do not correspond to the corresponding numbers in the risk assessment forms. After discussing this by phone with the City of Copenhagen, the municipality subsequently sent an Excel sheet titled "DPO - Mapping." Reference numbers referred to in the impact analysis correspond to the numbers in this Excel sheet. The Data Protection Agency has understood from the City of Copenhagen that the template in the Excel sheet has not been implemented in operation, and therefore it has not been filled out. The template contains 91 questions regarding whether various types of measures have been implemented. The City of Copenhagen stated in this context that the reference numbers in the impact analysis may not have been updated in connection with the municipality's decision not to use the "DPO - Mapping" template in operation. The Data Protection Agency has understood that this is the reason why the reference numbers do not correspond to the numbers in the submitted risk assessment forms, which were used instead of the "DPO - Mapping" template. The City of Copenhagen has additionally stated that the "DPO - Mapping" template is part of the preparatory work for the risk assessment concept that was used in 2020 and 2021. In this context, the City of Copenhagen noted that although the template has not been used in operation, it still points to the risk scenarios/the logic that underpinned the individual questions in the applied risk assessment concept.

3.3. Use of AULA

3.3.1. Supervisory report from the data protection advisor

The Data Protection Agency has reviewed the submitted supervisory report dated December 21, 2022, from the City of Copenhagen's data protection advisor. The report states that the municipality's data protection advisor, at the request of the municipality's citizen advisor, has investigated the storage of electronic child and student files in the IT systems SharePoint and AULA. The Data Protection Agency has understood from the supervisory report that the City of Copenhagen's data protection advisor concludes that the municipality has instructed schools and institutions to use AULA for purposes for which it was not originally intended, and that the necessary assessments, including risk assessments regarding documentation, archiving, and practical use in institutions and schools, have not been carried out in this context. The following is stated in the supervisory report regarding the data protection advisor's observations concerning the use of AULA: "Use of Aula In BUF, it has been decided in the school sector that notes and other written information about students, containing personal data, must be stored in AULA. In the daycare sector, it has been decided that notes and other written information about students containing personal data must be stored in AULA or Hjernen & Hjertet. The administration has instructed schools and institutions in the use of a solution that has neither been intended for the purpose nor could meet...

the administration has further instructed on the use of AULA secure file sharing, without having conducted the necessary assessments, including, among other things, risk assessments in relation to documentation, archiving, and practical application in institutions and schools. The administration has stated that it aimed for AULA to become the documentation system for daycare and schools. It is the administration's assessment that this will not be fulfilled. The challenge of documentation in schools and daycare is something the administration remains aware of, and efforts are underway to find a

lasting solution targeted at the sector, including ensuring that the notes, etc., currently stored in AULA secure file sharing will be documented. This work is currently ongoing in collaboration with KIT with a view to utilizing existing systems in the municipality.

3.3.2. Copenhagen Municipality's Comments

Copenhagen Municipality has, in two statements to the Data Protection Agency, responded to the agency's questions regarding the internal audit report from the municipality's data protection advisor. In this context, Copenhagen Municipality has stated that the Child and Student Folders have been phased out, and that data has been documented in the municipality's ESDH system. The municipality has indicated that there has never been any transfer of data/files from the Child and Student Folders to AULA.

In relation to the data protection advisor's report, Copenhagen Municipality has clarified that the Child and Youth Administration in the municipality has never advised on or used AULA for documentation or instructed that notifications and investigations should be placed in AULA, even though it may be interpreted that way in the report. In this connection, the municipality has stated that it is the Child and Youth Administration's view that the report's focus on documentation versus note obligation gives a misleading picture of the practice for document management and the use of AULA secure files in the municipality.

Furthermore, it is the Child and Youth Administration's opinion that it is not correct that AULA cannot handle the storage of pedagogical documentation. In this regard, the municipality has noted that the Secure File Sharing and messaging function in AULA is designed to support daily work and documentation. In this context, the municipality refers to KOMBIT's user guide, which states, among other things, that AULA provides the opportunity to collect sensitive personal data in one secure place. Copenhagen Municipality has noted that they have pointed this out to the municipality's data protection advisor.

Copenhagen Municipality has also stated that secure files in AULA are created based on the following templates:

- Agenda
- Pedagogical note (worksheet + status sheet)
- Recommendation for placement from a general daycare spot
- Reporting of the use of force
- Observation
- Communication book (respectively for grade 0, grades 1-6, grades 7-9)
- Parent meeting
- Concern, episode
- Network meeting (agenda and minutes)
- Minutes.

In this connection, the municipality has stated that there is no template for support applications, investigations, and notifications, as these areas of work are handled in specialized systems elsewhere in the Child and Youth Administration and the Social Administration.

Regarding the purpose of storing files in AULA, Copenhagen Municipality has stated that it is to:

- Support pedagogical work / pedagogical documentation (note obligation), and
- Ensure communication between school/daycare and home.

Copenhagen Municipality believes that the use of AULA as a communication platform and tool for pedagogical documentation, including compliance with the note obligation, falls within AULA's purpose and the purposes contained in the conducted risk assessments. Additionally, the municipality has stated that the municipality's impact analysis for AULA also includes the processing activities related to the purpose of supporting pedagogical work/pedagogical documentation (note obligation). In this connection, the municipality has stated that pedagogical documentation is relevant for communication and parent collaboration.

Copenhagen Municipality has further stated that an update of the impact analysis is planned for the fall of 2023. In this context, the municipality has stated that no impact analysis has been conducted since April 2021, as there have been no significant changes in the use of AULA. According to the municipality, efforts have been made in the interim period to minimize risks in AULA, for example, by no longer sending documents as PDF files but as rights-managed links.

Copenhagen Municipality has then stated that...

the analysis of consequences from April 2021 is accurate except for the legal basis and target group, which should have been updated with relevant professional legislation and the number of registered users following the rollout of AULA to the municipality's daycare services. The City of Copenhagen has stated that work is underway on a new system for secure files, with the aim of creating an improved solution that facilitates the work of pedagogical staff and ensures automatic documentation of relevant documents in the municipality's ESDH system. Finally, the City of Copenhagen has indicated that they agree with the data protection advisor that a permanent solution must be found as soon as possible to technically support the documentation needs. In this context, the municipality has stated that in the fall of 2022, they chose to initiate a documentation project to ensure relevant IT support for document management and documentation tasks that support the daily operations of schools and institutions. It is further stated that the municipality was in the process of implementing a pilot project in 2023 with a view to full implementation in the third quarter of 2024. The municipality has indicated that they originally, similar to other municipalities in the country, expected that the documentation task would be solved either directly in AULA or through an integration option with the ESDH system.

3.3.3. KOMBIT's material

The City of Copenhagen has, among other things, submitted KOMBIT's notes regarding ten modules in AULA, where a risk and consequence assessment has been conducted. The following is included in KOMBIT's description of Secure File Sharing:

"To ensure that all institutions can safely work with and store files containing sensitive personal data or confidential information, there is an area in AULA called Secure File Sharing.

In connection with the requirements specification of AULA and the identification of the need for storage of sensitive personal data about children, it became clear that this information could be found in many different systems as well as in paper form, both printed and in notebooks. It was therefore often difficult for teachers and pedagogues to form a complete picture of a child. It was therefore decided that the solution should support secure storage of both notes (as in the class log in SkoleIntra) as well as several types of documents, e.g., recommendations or scratch forms in one overview, which is not currently supported in SkoleIntra. Furthermore, it was also decided that documents created in other systems should be able to be imported into Secure File Sharing to support a single storage location for documents about a child.

[...]

In Secure File Sharing, the user only has access to view the documents that are shared with the user or the group of which the user is a member.

In Secure File Sharing, documents can be divided into a number of document categories:

- Agenda
- Action Plan
- Recommendation
- Use of Force Form
- Observation
- Educational Note
- Minutes
- Scratch Form
- Open Template

Secure File Sharing is always based on a child or a group, and a document must therefore always be linked to a group and can also be linked to an individual child. If the document is linked to a group, it is technically linked to all users in the group.

[...]

Actual cases and documents related to this must be handled in the municipality's ESDH system or special case management systems and not in AULA. It is therefore important to distinguish between a case management system containing notes and cases and AULA, which is a communication system. Actual case management should take place in a system designed for this purpose (e.g., an ESDH or a specific professional system like DUBU).

[...]"

The City of Copenhagen has, as mentioned above under point 3.2.1., submitted risk assessment material from KOMBIT, including risk assessments of five different data processes in AULA (Administration of users and groups, Login and user information, Communication and collaboration in primary schools, Communication and collaboration in daycare services, Sharing of information with other IT solutions) and 10 modules in AULA.

It appears from the risk assessment forms regarding the purpose of communication and collaboration in both school and daycare services (data processes 3 and 4) that it includes the storage and sharing of documents and files containing sensitive or confidential personal data. Furthermore, it appears from the risk assessment form regarding the module Secure File Sharing that the purpose is communication and collaboration among users in AULA. It is further stated that to ensure that all institutions can safely work with and store files containing sensitive or confidential personal data, there is an area in AULA called Secure File Sharing.

3.4. Reported breaches of personal data security regarding AULA

The background for the Data Protection Agency's initial decision to supervise the municipalities with a particular focus on the technical and organizational security measures that have been observed to meet the requirement for an appropriate level of security for the processing in AULA is that the agency has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA.

In AULA, personal data is processed, including

confidential and sensitive personal data about vulnerable registered individuals, including children. Furthermore, the system's users are often individuals who do not primarily work with data protection (including educators, pedagogical staff, as well as students and parents), which, in the opinion of the supervisory authority – in light of the many reported breaches from the vast majority of the country's municipalities – may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32, as well as mitigating measures for compliance with the regulation's Article 25. A large portion of these reports of breaches of personal data security in AULA concern instances where personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file regarding a child has been sent to another child's parents, or where a message has been mistakenly sent to a group of recipients instead of a specific recipient. The Data Protection Authority has also seen cases where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintended disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, settings for pedagogical-psychological assessments, information about dyslexia, school statements, as well as action plans and assessments regarding educational readiness. Upon an immediate search in the Data Protection Authority's ESDH system, the authority can ascertain that it has received at least 35 reports of breaches of personal data security from the Municipality of Copenhagen under the data protection regulation's Article 33, where AULA is mentioned in the report. The majority of the reports concern incidents where a message in AULA has been sent to one or more incorrect recipients. For instance, there are cases where a pedagogical psychological assessment was sent to another child's parents, and where a message containing information about a child's dyslexia was sent to another pair of parents in the same class. Additionally, there is a case where a parent group of 72 individuals was mistakenly added to an AULA message thread for staff, which included meeting minutes from staff meetings containing information about children in the institution and their families. There is a similar incident where a teacher intended to send a message to a pair of parents regarding their son but mistakenly sent the message to 94 unrelated recipients, including staff from other schools in the

municipality. Furthermore, the Data Protection Authority has received a report from the municipality regarding unauthorized access to information about whether contacts in AULA (parents) have custody over a child or not. The Data Protection Authority has also received three reports from the municipality concerning unauthorized access to information in AULA, where unauthorized individuals have logged into some AULA users' profiles, as they in two of the cases have gained access to login information.

4. Justification for the Data Protection Authority's Decision

4.1. Risk Assessment

The Data Protection Authority assumes that the Municipality of Copenhagen has subscribed to the submitted risk assessments for AULA, which KOMBIT has prepared, but that the Municipality of Copenhagen's risk assessment differs in one area from KOMBIT's risk assessment. The Data Protection Authority understands that it is in relation to the risk of unauthorized access to AULA and data due to insufficient user authentication and unauthorized access to data due to lack of or insufficient separation of functions in system accesses, where the Municipality of Copenhagen does not agree with KOMBIT's assessment that unauthorized access as a consequence is unlikely. The Data Protection Authority has thus conducted a sample review of KOMBIT's risk assessment material and a review of the Municipality of Copenhagen's risk assessment titled "Risk Assessment of AULA. Review of the IT System." The Data Protection Authority has also reviewed the other material submitted by the Municipality of Copenhagen, including the recommendation for the extension of the exemption for user management of AULA, the background note on the work with security in AULA, the timeline for the municipality's work to address the security challenge in AULA, and the submitted copy of the municipality's inquiries to KOMBIT regarding the development of AULA's messaging module. The Data Protection Authority has also conducted a sample review of the Municipality of Copenhagen's risk assessment forms, which have been submitted as a supplement to the municipality's impact assessments.

4.1.1. Relevant Rules

The General Data Protection Regulation requires, on several points, that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to. It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller must address the risk to the rights and freedoms of the data subjects. Furthermore, it follows from both Article 5, paragraph 2, regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules. Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of the data subjects must take place before the processing is initiated. It follows from the General Data Protection Regulation's Article 5, paragraph 1, letter f, that personal data must be processed in a manner that ensures adequate security for the personal data in question, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures.

****4.1.1. Responsibilities of the Data Controller****

The data controller must also be able to demonstrate that the fundamental principles are adhered to, as stipulated in Article 5, paragraph 2 of the Data Protection Regulation. According to Article 32, paragraph 1 of the Data Protection Regulation, the data controller must take appropriate technical and organizational measures to ensure a security level that is appropriate to the risks associated with the data controller's processing of personal data.

It follows from Article 24, paragraph 1 of the Data Protection Regulation that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in compliance with the regulation. The data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks.

Furthermore, the data controller must be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the

supervisory authority to assess whether an appropriate level of security has been ensured, it must be documented and explained which risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

****4.1.2. General Requirements for Risk Assessment****

The Data Protection Authority notes that the Data Protection Regulation does not specify how detailed the risk assessment should be. It is the opinion of the Data Protection Authority that the data controller must establish an appropriate level considering the risks that are relevant to the data controller's processing of personal data.

If a supplier, data processor, or available analyses determine or indicate specific risk scenarios, it is the opinion of the Data Protection Authority that data controllers should take these assessments into account, particularly when processing activities in a system are deemed to involve high risks for the data subjects. At a minimum, there should be a substantiated assessment of why the matter is not relevant in the processing of personal data that occurs with the data controller.

It is not explicitly stated anywhere in the Data Protection Regulation how the documentation should look, what the specific content should be, or what the frequency of updates and revisions should be. The Data Protection Authority finds that the documentation obligation implies that the supervisory authority – from the total material that the data controller can present – can assess whether the processing is in compliance with the Data Protection Regulation.

Thus, it should be evident from the submitted material how and on what basis the data protection considerations have been made. This includes, among other things, the legality of the processing, the ability to ensure compliance with the rights of the data subjects, adherence to the data protection principles, and ensuring an appropriate level of security.

Additionally, it should be clear what considerations, choices, and omissions have been made to ensure that the processing of the information is in accordance with the Data Protection Regulation. In this context, it should be possible to timestamp when and with what content relevant considerations and actions have taken place.

It is the opinion of the Data Protection Authority that a risk assessment should include an evaluation of the consequence (e.g., high, medium, low) for the data subjects in the event of loss of confidentiality, availability, and integrity. Subsequently, the risk assessment should identify what threats exist regarding the loss of confidentiality, availability, and integrity, as well as the likelihood (e.g., high, medium, low) that the threat will materialize. Finally, the risk assessment should map the existing security measures and their contribution to reducing the risk. Based on this, the data controllers can assess the risk and determine whether it is an acceptable risk or if further measures need to be implemented. By addressing these elements in a risk assessment, the data controllers can document how they have assessed the risk to the data subjects from the relevant processing activities, as well as on what basis they believe that the implemented measures have reduced the risk.

****4.1.3. Identification and Assessment of Risks by the City of Copenhagen****

Following a sample review of the submitted risk assessment material prepared by KOMBIT, as well as a review of the City of Copenhagen's risk assessment titled "Risk Assessment of AULA. Review of the IT System" and other material from the City of Copenhagen, the Data Protection Authority can confirm that the City of Copenhagen has identified a number of risks for the data subjects in the processing of personal data in AULA. The material from KOMBIT shows that an assessment has been made of the consequences for the data subjects in the event of loss of confidentiality, integrity, and availability, as well as an assessment of the likelihood that the threats will materialize.

The City of Copenhagen appears to have taken these risk assessments from KOMBIT into account in the municipality's risk assessment as well as in the submitted background note regarding the work on security in AULA. It is evident from the City of Copenhagen's risk assessment that the municipality shares the views expressed in KOMBIT's risk assessment and that the municipality's mitigating actions

actively align with KOMBIT's risk assessment.

However, the City of Copenhagen's risk assessment differs, as mentioned, in one area from KOMBIT's risk assessment concerning the assessment of the risk of unauthorized access due to insufficient... userSure! Here is the translation of the provided legal document text into English, preserving the meaning and important formatting cues:

****User Authentication and Lack of or Insufficient Separation of Functions in System Access.****

The Data Protection Agency finds that, based on this, the City of Copenhagen has demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data poses to the data subjects. The City of Copenhagen appears to have documented how it has assessed the risk to the data subjects regarding the relevant processing activities, as well as how it has addressed KOMBIT's risk assessment.

****4.1.4. Description of Security Measures by the City of Copenhagen****

Upon reviewing the material submitted by the City of Copenhagen, including particularly the background note on the work with security in AULA, the timeline for the municipality's efforts to address the security challenges in AULA, the submitted copy of the municipality's inquiries to KOMBIT regarding the development of AULA's messaging module, and the risk assessment titled "Risk Assessment of AULA. Review of the IT System," the Data Protection Agency finds that the City of Copenhagen appears to have worked very seriously and purposefully to reduce the identified risks. In this context, the City of Copenhagen particularly seems to have worked on reducing the risk that the use of UNI-login entails, according to the municipality's assessment.

Furthermore, the City of Copenhagen has addressed in the material which measures it can implement itself and which technical measures it needs to request the supplier to implement. The Data Protection Agency has also determined, through a general review of the described measures, that the measures appear to be relevant in relation to reducing the various risks.

However, it is not clearly indicated that the City of Copenhagen has addressed all the identified risks in their risk assessment regarding their description of measures, including the risks that appear in the risk assessment material from KOMBIT. The information in the risk assessment and the other documents does not seem to be structured in a way that clearly shows which measures have been implemented in relation to the individual identified risks.

The Data Protection Agency can also ascertain that it is not evident from the risk assessment how the City of Copenhagen has assessed the identified risks after the implemented measures. It is merely stated that an acceptable level of security can be achieved in the solution for the elements that fall within the administration's scope of action regarding AULA. The Data Protection Agency notes in this context that the municipality, as the data controller for the processing of personal data in AULA, is responsible for ensuring and being able to demonstrate that the processing is in compliance with the General Data Protection Regulation. This follows from Article 24, paragraph 1 of the General Data Protection Regulation. This applies even if it is outside the data controller's scope of action to implement all relevant measures that must ensure this in relation to the processing of personal data in an IT solution. An assessment of the risk to the rights and freedoms of the data subjects cannot therefore be limited to concern only the elements that fall within the data controller's discretion.

After a sample review of the City of Copenhagen's risk assessment forms from 2020 and 2021, which have been submitted as a supplement to the municipality's impact assessments, the Data Protection Agency can, however, ascertain that the municipality has addressed a number of risks, including risks that are not immediately mentioned in the risk assessment titled "Risk Assessment of AULA. Review of the IT System." Furthermore, the municipality appears to have made an assessment in the 2020 risk assessment form regarding the effect of implementing various measures on the risk (where affirmative responses were given to the control questions).

However, it is not clearly stated whether and, if so, how these risk assessment forms relate to the other

material mentioned above in this section. The City of Copenhagen has only stated that these forms should be seen as a supplement to the impact assessments. The Data Protection Agency has not conducted a thorough investigation into whether and, if so, how there is a connection between all the identified risks, including the risks that appear in KOMBIT's risk assessment material, and the measures described in the risk assessment titled "Risk Assessment of AULA. Review of the IT System" and the two risk assessment forms from 2020 and 2021. This would be a large and resource-intensive task, as the municipality has not structured the various materials in a way that allows for the connection to be deduced.

Based on a review of the total material, the Data Protection Agency finds that the City of Copenhagen has not fully demonstrated that it has implemented appropriate measures to reduce all the identified risks, including the risks that appear in the risk assessment material from KOMBIT. The Data Protection Agency has noted that the City of Copenhagen is working on a revised risk assessment concept. Therefore, the Data Protection Agency recommends that the City of Copenhagen structures the information in the revised risk assessment concept in a way that allows for comparisons of risk assessments before and after the measures have been implemented, and so that the connection between measures and the individual risks is clear. In this way, an overview can be created that can help ensure that all identified risks have been assessed and managed through the implementation of appropriate security measures.

In its assessment of whether a data controller has demonstrated that it has ensured an appropriate level of security, the Data Protection Agency considers all the factual circumstances and...

Please let me know if you need any further assistance!

****Documentation regarding whether the supervision, based on the overall material, is assured that there is a connection between all identified risks and the implemented measures, and whether these measures are deemed sufficient to reduce the identified risks.****

4.1.5. ****Particularly regarding the risk of erroneous sending in AULA's messaging module****

It is generally the opinion of the Data Protection Agency that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous sending, or whether it is possible to design the messaging function in a way that mitigates such risk.

In this context, the Data Protection Agency recommends that the City of Copenhagen, together with KOMBIT and the other data-controlling municipalities, conduct such an investigation. This is particularly relevant considering that AULA's users are often individuals who do not primarily work with data protection (teachers, educational staff, and parents), which, in the view of the agency—given the numerous reported breaches—may imply that stricter requirements should be imposed on the data controller's observance of both technical and organizational measures pursuant to Article 32.

In this regard, the Data Protection Agency can mention that it has found that AULA's messaging module is designed in such a way that in messages sent to multiple recipients, it is most obvious to reply to all persons in the message thread. There is a less visible field where it is possible to reply directly to the sender of the message. However, in the field where the user replies to all in the message thread, there is information about how many persons the user is replying to. Such a design of the messaging function, in the opinion of the Data Protection Agency, entails a risk that users of AULA inadvertently send a message to all recipients in a message thread instead of solely to the sender of the message. In this context, there is a risk that sensitive or confidential personal data is unjustifiably disclosed to incorrect recipients.

Furthermore, the Data Protection Agency has found that recipient suggestions are automatically generated when the user begins to type in the recipient field "To." In this context, both employees, children, and parents are suggested as recipients. This entails, in the opinion of the Data Protection Agency, a risk that users select one or more incorrect recipients from the list of suggested recipients, or that they select, for example, all suggested parents whose first name or last name contains the

entered letters, instead of one specific recipient.

4.1.6. ****Overall assessment regarding risk assessment****

After a random review of KOMBIT's risk assessment material and a review of the City of Copenhagen's risk assessment titled "Risk Assessment of AULA. Review of the IT System" as well as the other material submitted, the Data Protection Agency finds that the City of Copenhagen has demonstrated that it has identified the most significant risks that the municipality's processing of personal data in AULA poses to the registered individuals. Thus, the City of Copenhagen appears to have documented how it has assessed the risk to the registered individuals from the relevant processing activities, as well as how it has responded to KOMBIT's risk assessment.

The City of Copenhagen appears to have worked very seriously and purposefully to reduce the identified risks. In this context, the City of Copenhagen has particularly worked to reduce the risk that the use of UNI-login entails, according to the municipality's assessment.

However, it is the opinion of the Data Protection Agency that the City of Copenhagen has not fully demonstrated that the municipality has implemented appropriate measures aimed at reducing all identified risks, including the risks outlined in the risk assessment material from KOMBIT.

The Data Protection Agency has noted that the City of Copenhagen is working on a revised risk assessment concept. Therefore, the Data Protection Agency recommends that the City of Copenhagen structures the information in the revised risk assessment concept in such a way that it is possible to compare the assessments of risks before and after the measures have been implemented, and that the connection between measures and individual risks is clear. In this way, an overview can be created that can help ensure that all identified risks are assessed and managed through the implementation of appropriate security measures.

In choosing a response, the Data Protection Agency has emphasized that the City of Copenhagen appears to have worked on and attempted to reduce the identified risks. Thus, the City of Copenhagen appears to have implemented measures that fall within the municipality's scope of action and has contacted KOMBIT with proposals for solutions to various issues. Furthermore, the City of Copenhagen has actively engaged with KOMBIT's risk assessment, where the municipality has assessed that its risk assessment differs from KOMBIT's risk assessment in one area.

However, the City of Copenhagen's risk assessment and the other submitted material, including the risk assessment forms that supplement the impact analysis, are, in the opinion of the Data Protection Agency, not sufficiently detailed or structured in a way that clearly indicates whether and, if so, how the municipality has addressed all identified risks in their description of measures, including the risks outlined in the risk assessment material from KOMBIT. It is also not clearly stated whether and, if so, how there is a connection between the submitted material where the municipality has conducted a risk assessment.

4.2. ****Impact Analysis****

4.2.1. Requirement for a Consequence Analysis

It follows from Article 35, paragraph 1 of the Data Protection Regulation that if a type of processing, particularly through the use of new technologies and by virtue of its nature, scope, context, and purposes, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall carry out an analysis of the intended processing activities' consequences for the protection of personal data prior to the processing. A single analysis may encompass several similar processing activities that involve similar high risks.

In the guidelines on consequence analysis regarding data protection from the Article 29 Working Party (now the European Data Protection Board, EDPB)[6], criteria are established that can help identify the processing activities that will require a consequence analysis. According to the guidelines, a data controller can generally assume that processing which meets two of the criteria must be subject to a consequence analysis regarding data protection.

The processing of personal data in AULA meets two of these criteria, as sensitive and confidential personal data about vulnerable data subjects, including children, is processed. Furthermore, it concerns a system used for collaboration and communication between schools/daycare institutions and children and their parents. In the system, personal data is exchanged in messages, among other

things, and there are many users associated with the system. The Data Protection Authority believes that this communication entails a risk that, due to human errors, personal data may be inadvertently disclosed to incorrect users. This is particularly relevant considering that the users consist of both municipal employees as well as children and their parents, and that – regardless of guidance – human errors will occur for which there are no immediate mitigating measures.

Generally, based on the types of information processed in AULA, the volume of information, the number of transactions (exchange of information in connection with communication), and the diversity of users, there is not only a potential risk that the risk scenario will occur but also a real one.

The consequences for the rights of the data subjects can, in the opinion of the Data Protection Authority, range across almost the entire spectrum of severity of consequences, from the less intrusive, such as receiving unintended messages, to more serious ones, such as significant loss of reputation, to the extreme consequence where a data subject's life is endangered by the disclosure of a concealed address, to mention just a few possible consequences.

The Data Protection Authority notes that any risk that involves a high consequence for the rights and freedoms of data subjects – even with relatively low probabilities of the risk materializing – will likely entail a high risk for the rights of the data subjects, which triggers the obligation to conduct a consequence analysis regarding data protection, cf. Article 35, paragraph 1 of the Regulation.

Furthermore, based on reports of personal data security breaches concerning AULA, the Data Protection Authority has generally found that several of these would likely entail a high risk to the rights and freedoms of natural persons. Additionally, the Authority has noted in several instances that municipalities have deemed the conditions in Article 34 to be met and have informed the data subjects about breaches of personal data security in AULA. The municipalities in question have thus assessed that the breaches likely pose a high risk to the rights and freedoms of natural persons.

Based on the above, the Data Protection Authority agrees with the assessment of the City of Copenhagen that the processing of personal data in AULA entails a high risk to the rights and freedoms of natural persons.

The Data Protection Authority therefore finds that the processing activities carried out in AULA are subject to the requirement for a consequence analysis regarding data protection prior to the implementation of AULA.

4.2.2. Timing for the Preparation of the Consequence Analysis

It follows from Article 35, paragraph 1 of the Data Protection Regulation that a consequence analysis regarding data protection must be conducted prior to the processing.

The Data Protection Authority assumes that the City of Copenhagen's consequence analysis was prepared on March 3, 2020, as this date is indicated on the front page of the consequence analysis.

The Data Protection Authority has also received an updated version of the consequence analysis, which appears to have been prepared on April 20, 2021.

In connection with a supervisory visit to KOMBIT in December 2019, the Data Protection Authority found that there had been ambiguity regarding where the data responsibility for the processing of personal data in the solution was placed in connection with the development of AULA. Both the municipalities and KOMBIT had thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thus also the responsibility for conducting risk assessments and consequence analyses – was placed with KOMBIT.

As noted above under point 1, the Data Protection Authority established during the supervisory visit to KOMBIT that KOMBIT was not to be regarded as the data controller, and therefore the Authority informed KOMBIT that it should ensure that all municipalities were informed of their data responsibilities, and that KOMBIT should transfer all necessary materials and information to the municipalities in that regard.

The Data Protection Authority can further ascertain that the City of Copenhagen has addressed its responsibilities in relation to data protection regulations in March 2020. It appears from the submitted background note on the work with security in AULA in the Children and Youth Administration that when it was a municipal matter...

decision to implement AULA, it is up to the municipalities to assess whether the system and the

infrastructure to which the system is subject (UNI-login) comply with the General Data Protection Regulation (GDPR). The Data Protection Agency assumes that this uncertainty regarding data responsibility has been a reason why the consequence analysis of the City of Copenhagen was not prepared prior to their processing of personal data in AULA. In this context, the Data Protection Agency assumes that the City of Copenhagen, upon the implementation of AULA, believed that KOMBIT was the data controller for the processing of personal data in the solution and thus also responsible for the preparation of a risk assessment and consequence analysis.

Based on the Data Protection Agency's supervisory visit to KOMBIT in December 2019 and the material submitted by KOMBIT in this regard, the Data Protection Agency assumes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities were data controllers – conducted assessments of the risks and consequences for the data subjects regarding the processing of personal data in AULA, which show that the processing involves a high risk for the data subjects.

It is thus the opinion of the Data Protection Agency that the City of Copenhagen – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA in connection with KOMBIT informing the municipalities about their data responsibility regarding the processing of personal data in AULA and transferring all necessary material in that regard. The Data Protection Agency expects that KOMBIT informed the municipalities about this immediately after the supervisory visit in December 2019.

The Data Protection Agency can confirm that the City of Copenhagen prepared a consequence analysis in March 2020, approximately three months after clarity regarding data responsibility was established.

On this basis, the Data Protection Agency assumes that the City of Copenhagen, immediately after the determination of the municipality's data responsibility for the processing of personal data in AULA and the high risk that the processing entails, commenced the preparation of a consequence analysis, which was completed approximately three months thereafter.

The Data Protection Agency finds that the City of Copenhagen, regarding the timing of the preparation of their consequence analysis, has acted in accordance with Article 35, paragraph 1 of the General Data Protection Regulation.

4.2.3. Minimum Requirements for Consequence Analyses

Article 35 of the General Data Protection Regulation contains a number of requirements that a consequence analysis must meet at a minimum. These requirements follow from paragraph 7 and include the following:

1. a systematic description of the planned processing activities and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller
2. an assessment of whether the processing activities are necessary and proportionate to the purposes
3. an assessment of the risks to the rights and freedoms of the data subjects as referred to in paragraph 1, and
4. the measures that are envisaged to address these risks, including safeguards, security measures, and mechanisms that can ensure the protection of personal data and demonstrate compliance with this regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons.

The rules of the General Data Protection Regulation regarding consequence analysis are intended to ensure that no processing, where there is an inherent high risk to the rights and freedoms of the data subjects, is initiated without the data controller having worked on and mitigated such risks.

A consequence analysis regarding data protection is thus a tool that enables the data controller to systematically address the risks that a processing activity may entail.

The General Data Protection Regulation provides data controllers with the flexibility to determine the exact structure and form of the consequence analysis regarding data protection. However, regardless of the form, a consequence analysis regarding data protection must contain the above minimum requirements and thus be a proper assessment of risks that enables the data controllers to take measures to mitigate them.

The Data Protection Agency has reviewed the City of Copenhagen's consequence analysis in relation to the minimum requirements in Article 35, paragraph 7 of the General Data Protection Regulation. In this context, the Data Protection Agency has particularly looked at the content of the latest submitted version of the consequence analysis from April 2021 and compared it with the previous version from March 2020.

The Data Protection Agency has noted that the City of Copenhagen had planned an update of the consequence analysis in the autumn of 2023 based on the municipality's new concept for risk assessments including consequence analyses.

It is the Agency's overall assessment that the City of Copenhagen has not conducted a sufficient consequence analysis, according to Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted consequence analysis does not meet the minimum requirements for this, according to Article 35, paragraph 7, letters a-d. The consequence analysis does not, among other things, contain assessments of necessity and proportionality.

Below follows the Data Protection Agency's assessment of the consequence analysis in relation to the individual minimum requirements that follow from Article 35, paragraph 7, letters a-d.

Ad a) Systematic description of processing activities and purposes

It is the opinion of the Data Protection Agency that the requirement for a systematic description of the planned...

****Processing Activities and Purposes of Processing****

pursuant to Article 35, paragraph 7, letter a of the Data Protection Regulation, implies that the data controllers must carry out a systematic description of the various forms of processing, e.g., collection, registration, disclosure, etc., to which personal data will be subject, as well as a clear description and definition of the personal data being processed. Furthermore, the requirement entails that the impact assessment must include a description of the purpose of the processing.

Additionally, it is the opinion of the Data Protection Authority that a systematic description should include information about the legal basis for the processing (authority), which categories of data subjects the information pertains to, the number of data subjects, information about where the data comes from, who—within and outside the organization—can access the data, how long the data is stored, whether data is transferred to third countries (and on what basis), and whether new technologies are used for the processing of personal data.

Thus, the systematic description should contribute to the data controller's assessment of the specific likelihood and severity of high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. In this connection, the Data Protection Authority refers to recital 90[7].

The Data Protection Authority can ascertain that the impact assessment from the Municipality of Copenhagen includes, among other things, information about various forms of processing activities that personal data undergoes in AULA, the purpose of processing personal data, the number of data subjects, information that the data originates from KMD student (school), UNI-login, and KMD institution (daycare), and how long the data is stored.

Furthermore, it appears from the impact assessment that information about school students, employees, and parents/contact persons is processed. The Data Protection Authority has understood from the impact assessment that the Municipality of Copenhagen assesses that there are no special citizen considerations in the processing of personal data in AULA. It is the opinion of the Data

Protection Authority that there are special citizen considerations present in the municipalities' processing of personal data in AULA, as information about children, who are vulnerable physical persons, is processed. The Data Protection Authority notes in this connection that children and young people have the right to special protection of their personal data according to the rules in the Data Protection Regulation. The Data Protection Authority refers in this connection to recital 38[8] of the regulation.

The impact assessment also contains information about which types of personal data are processed. However, it is not stated which categories of personal data are involved, including whether they pertain to special categories of personal data (sensitive personal data), ordinary personal data, and/or confidential personal data. However, the Data Protection Authority can ascertain from the listing of the types of data that there are both ordinary, confidential, and sensitive personal data involved.

Regarding the legal basis for the processing in AULA, the following is stated in the impact assessment: "The Folkeskole Act 45(2)(2)." However, it does not appear what the legal basis in the Data Protection Regulation is for the processing of personal data.

Furthermore, it does not appear from the impact assessment who—within and outside the organization—can access the data, whether there is a transfer of data to third countries (and on what basis), or whether new technologies are used for the processing of personal data.

In light of this, it is the assessment of the Data Protection Authority that the Municipality of Copenhagen has described their processing activities in AULA and the purpose of the processing, but that the description is not sufficiently detailed, as it does not contain the aforementioned information. Thus, the minimum requirement in Article 35, paragraph 7, letter a is not met.

****b) Assessment of Necessity and Proportionality****

The Data Protection Authority can ascertain that the Municipality of Copenhagen's impact assessment does not contain an assessment of whether the processing activities are necessary and proportionate to the purposes, which is a requirement under Article 35, paragraph 7, letter b.

****c) and d) Assessment of Risks and Measures****

The Municipality of Copenhagen's impact assessment contains an assessment of the risks to the rights and freedoms of the data subjects if 12 conditions are not managed. It is indicated whether the Municipality of Copenhagen assesses the risk to be low, medium, or high. However, it does not appear what the basis for this assessment is, including how the likelihood and severity of the risk have been evaluated.

The Data Protection Authority can ascertain that the risk assessment form from 2020, which the municipality has submitted as a supplement to the impact assessment, contains an evaluation of the likelihood and consequence concerning a number of threats. In this connection, a number of control questions regarding various measures have been answered. The Data Protection Authority has understood that these assessments are the basis for the information in the impact assessment. However, the connection between the impact assessment and the underlying assessments in the risk assessment forms is not clearly evident, as the references in the impact assessment to reference numbers in the risk assessment do not correspond to the numbers in these risk assessment forms. As noted in section 3.2.2 above, the Data Protection Authority has understood that this is due to the reference numbers not being updated by mistake after the municipality decided to use a different template for the risk assessments that supplement the impact assessment.

Furthermore, the Data Protection Authority can ascertain by comparing the impact assessment and the underlying...

Risk Assessment Form with KOMBIT

Risk assessment material indicates that the impact assessment does not clearly address all identified risks. In this context, it is noted that the risk of users inadvertently sending personal data to incorrect recipients in the messaging function, where sensitive or confidential information is included in the message text, is not mentioned. Regarding the messaging function, it is only the risk that users may

read documents that they mistakenly receive in AULA as an attached readable file (instead of a link to a rights-managed document) that is discussed in the impact assessment.

However, the Data Protection Authority can, through a review of the other material from the municipality, particularly the risk assessment in the document titled "Risk Assessment of AULA. Review of the IT System," ascertain that the City of Copenhagen has identified this risk and actively worked to reduce it. Reference is made in this context to sections 4.1.3 and 4.1.4 above.

Based on this, the Data Protection Authority's overall assessment is that the content of the impact assessment regarding the municipality's evaluation of risks is insufficient. In this regard, the Data Protection Authority has particularly emphasized that there does not appear to be a clear correlation between the risk assessment in the impact analysis and the underlying assessment in the risk assessment forms regarding the likelihood and consequences related to a number of threats. It is therefore not clear to the Data Protection Authority what the basis is for the assessments of the relevant risks before and after the implemented measures.

The Data Protection Authority assesses that the content of the impact assessments and the underlying risk assessment forms is not sufficient to meet the minimum requirements of Article 35, paragraph 7, letters c and d.

It appears from the first version of the City of Copenhagen's impact assessment dated March 3, 2020, that there are two high-risk factors after the listed measures have been implemented. The Data Protection Authority has understood from the impact assessment from March 2020 and the other material submitted by the City of Copenhagen that the municipality assessed that the use of UNI-login was the cause of some of the identified high risks.

The Data Protection Authority has noted that the City of Copenhagen in their second version of the impact assessment dated April 20, 2021, has assessed that the two factors, which in March 2020 were assessed to pose high risks after the implemented measures, have been reduced to pose a medium risk.

The Data Protection Authority assumes that the City of Copenhagen has worked to reduce the high risks from March 2020 to April 2021, and that there have thus not been high risks that could not be reduced by the introduction of appropriate measures regarding available technology and implementation costs.

4.2.4. Requirement to Consult the Data Protection Officer

It follows from the Data Protection Regulation's Article 35, paragraph 2, that the data controller must consult the data protection officer, if one has been appointed, when conducting an impact assessment regarding data protection. This consultation must be documented in the impact assessment. It further follows from the Regulation's Article 39, paragraph 1, letter c, that the data protection officer must, at a minimum, advise, when requested, regarding the impact assessment concerning data protection and monitor its compliance according to Article 35.

It is not stated in the City of Copenhagen's impact assessment whether the municipality has consulted its data protection officer, and what comments the data protection officer may have had in that case.

It appears from a help text in the impact assessments' section with the overall assessment/conclusion that medium risks must not exceed 70%, and that all high risks must be eliminated. In this context, it is stated that the data protection officer should be contacted for further guidance if these conditions are not met.

In the first version of the impact assessment from March 2020, it is stated that there are two high-risk factors. However, it does not appear whether the City of Copenhagen has received (further) guidance from its data protection officer.

4.2.5. Renewed Impact Assessment

It follows from the Data Protection Regulation's Article 35, paragraph 11, that the data controller must conduct a renewed review if necessary to assess whether processing has been carried out in

accordance with the impact assessment regarding data protection, at least when there is a change in the risk posed by the processing activities.

It is the Data Protection Authority's opinion that a renewed review of the processing activities must be conducted to assess whether the processing has been carried out in accordance with the original impact assessment when the risk landscape changes, or the data controller assesses for another reason that it is necessary. This may, for example, be the case when such a change occurs that the risk posed by the processing activities becomes higher.

Furthermore, it must also be assessed whether there is a need for a renewed review when changes occur that mean that the purpose of the processing changes, and/or that other personal data than those currently processed will be processed in the future. This may be relevant, for example, if sensitive personal data will be processed in a system where only ordinary personal data has previously been processed.

The City of Copenhagen's data protection officer has concluded in an internal audit report that the municipality has instructed schools and institutions to use AULA for purposes for which it was not originally intended, and that there has not been any guidance in this context.
made the necessary assessments.

The Municipality of Copenhagen has stated that the purposes of processing personal data in AULA are to support pedagogical work/pedagogical documentation (documentation obligation) and to ensure communication between school/daycare and home. It is noted in the impact analysis that the purpose of processing personal data in AULA is solely "communication between school and home." However, the Municipality of Copenhagen has indicated that the municipality's impact analysis for AULA also includes the processing activities related to the purpose of supporting pedagogical work/pedagogical documentation (documentation obligation). In this context, the municipality has stated that pedagogical documentation is relevant for communication and parental cooperation.

It appears from KOMBIT's note on AULA's module Secure File Sharing that it was decided during the requirements specification that the solution should support the secure storage of both notes and various types of documents, e.g., recommendations or so-called scratch forms in one overview. Similarly, it was decided that documents from other systems should be importable to Secure File Sharing in AULA to support a single storage location for documents about a child. Reference is made to section 3.3.3 above.

Furthermore, it appears from KOMBIT's risk assessment forms regarding data processes 3 and 4 (communication and cooperation in schools and daycare, respectively) that communication and cooperation among users in AULA includes, among other things, the storage and sharing of documents and files containing sensitive or confidential personal data. It is also noted in KOMBIT's risk assessment form regarding the module Secure File Sharing that the purpose of processing personal data is communication and cooperation among users in AULA. In this context, it is stated that to ensure that all institutions can securely work with and store files containing sensitive or confidential personal data, there is an area in AULA called Secure File Sharing.

The Data Protection Agency has compared the templates listed by the Municipality of Copenhagen that are used in Secure File Sharing in AULA with the document categories listed in KOMBIT's note on Secure File Sharing. Reference is made to sections 3.3.2 and 3.3.3 above.

In this context, the Data Protection Agency has found that the Municipality of Copenhagen does not appear to use Secure File Sharing for other types of documents than those document categories listed by KOMBIT. In this regard, the Data Protection Agency has noted the information provided that the Municipality of Copenhagen does not use AULA for support applications, investigations, and notifications, as these areas of work are handled in specialized systems elsewhere in the municipality. The Data Protection Agency has also noted that the municipality does not use Secure File Sharing for actual case processing, but that this occurs in the municipality's ESDH system.

Furthermore, the Data Protection Agency can confirm that the Municipality of Copenhagen has clarified in relation to the internal report of the data protection advisor that the municipality has never advised or used AULA for journaling or instructed that notifications and investigations should be placed

in AULA.

The Data Protection Agency has not taken a position on whether the Municipality of Copenhagen uses Secure File Sharing for purposes other than those originally established and which are not covered by the municipality's impact analysis. However, the Data Protection Agency must note that a remark from the data controller's data protection advisor regarding the data controller's use of an IT solution should prompt the data controller to reconsider that use.

The Data Protection Agency recommends that the Municipality of Copenhagen – possibly in dialogue with other municipalities, KOMBIT, and KL – clarifies the purpose of processing personal data in AULA in the municipality's impact analysis. In this context, it is also relevant to clarify in the impact analysis which document types Secure File Sharing is used for, and what types of personal data these document types typically contain.

The Data Protection Agency has noted that the Municipality of Copenhagen is working on a new system for secure files, where the purpose is to create an improved solution that facilitates the work of pedagogical staff and ensures automatic journaling of relevant documents in the municipality's ESDH system.

The Municipality of Copenhagen has stated that the municipality has not conducted a new impact analysis following the rollout of AULA in the municipality's daycare in May 2021, and that this is an error. However, the Municipality of Copenhagen assesses that the impact analysis from April 2021 is accurate, except for the information regarding the legal basis and target group, which should have been updated with relevant professional legislation and the number of registered individuals. The municipality has also stated that it is their assessment that there is no difference in the use of AULA between daycare and schools.

However, it appears from the municipality's risk assessment titled "Risk Assessment of AULA. Review of the IT System" that the involvement of the Children and Youth Administration in daycare in June 2020 is a significant change that, according to the municipality's business circular for IT procurements, requires a new assessment of the system and an update of documentation.

The Data Protection Agency assumes that the rollout of AULA to the daycare centers in the Municipality of Copenhagen has, among other things, resulted in more users gaining access to AULA (both employees and parents of children in daycare), and that information about more registered individuals is being processed, which also means that more personal data is being processed in the system.

The Data Protection Agency further assumes that communication via AULA may also concern other topics. In this context, it is noted that the Municipality of Copenhagen has stated that Secure File Sharing contains a template for recommendations for visitation.

from a daycare placement.

The rollout of AULA to the daycare centers does not appear to have resulted in the processing of other types of personal data – as it continues to process ordinary, sensitive, and confidential personal data – nor has the purpose of processing personal data in AULA changed.

On this basis, the Data Protection Agency finds that the rollout of AULA to the daycare centers has not resulted in a change in the risk posed by the processing activities that would require the Municipality of Copenhagen to conduct a renewed review of the impact assessment in accordance with Article 35, paragraph 11 of the General Data Protection Regulation.

However, the Data Protection Agency must note that the Municipality of Copenhagen, when updating the impact assessment in April 2021, should have made the necessary corrections so that the impact assessment accurately reflected the rollout of AULA to the municipality's daycare centers in May 2021. The Data Protection Agency recommends that the municipality, in connection with the planned update of the impact assessment, ensures that the information in the impact assessment is accurate in relation to the fact that AULA is also used in the municipality's daycare centers.

4.2.6. Overall assessment regarding the impact assessment

After reviewing the Municipality of Copenhagen's impact assessment and the underlying risk assessment forms, the Data Protection Agency finds that the Municipality of Copenhagen, regarding the timing of the preparation of their impact assessment, has acted in accordance with Article 35, paragraph 1 of the General Data Protection Regulation.

However, it is the Data Protection Agency's assessment that the Municipality of Copenhagen has not conducted a sufficient impact assessment, cf. Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted impact assessment does not meet the minimum requirements set out in Article 35, paragraph 7, letters a-d of the Regulation.

On this basis, the Data Protection Agency finds grounds to criticize that the Municipality of Copenhagen's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation.

In choosing a response, the Data Protection Agency has emphasized that the Municipality of Copenhagen has prepared an impact assessment for the processing of personal data in AULA, which contains elements that appear in Article 35, paragraph 7, letters a, c, and d, and that the impact assessment was prepared immediately after the municipality's data responsibility for the processing of personal data in AULA was established, as well as the high risk that the processing entails. However, the description of the processing activities and the content regarding the municipality's assessment of the risks and the listed measures are, in the Data Protection Agency's assessment, insufficient to meet the minimum requirements in Article 35, paragraph 7, letters a, c, and d.

The Data Protection Agency has also emphasized that the impact assessment does not contain an evaluation of whether the processing activities are necessary and proportionate to the purposes, which is one of the minimum requirements for an impact assessment, cf. Article 35, paragraph 7, letter b. Finally, the Data Protection Agency finds that the rollout of AULA to the daycare centers has not resulted in a change in the risk posed by the processing activities that would require the Municipality of Copenhagen to conduct a renewed review of the impact assessment in accordance with Article 35, paragraph 11 of the General Data Protection Regulation.

The Data Protection Agency recommends that the municipality, in connection with the planned update of the impact assessment, ensures that the information in the impact assessment is accurate in relation to the fact that AULA is also used in the municipality's daycare centers.

Furthermore, the Data Protection Agency recommends that the Municipality of Copenhagen – possibly in dialogue with other municipalities, KOMBIT, and KL – clarifies the purpose of processing personal data in AULA in the municipality's impact assessment. In this context, it is also relevant to clarify in the impact assessment which document types Secure File Sharing is used for, and what types of personal data these document types typically contain.

4.3. Summary

On the above basis, the Data Protection Agency finds reason to recommend the Municipality of Copenhagen that the information in the municipality's revised risk assessment concept is structured in such a way that it is possible to compare the assessments of risks before and after the measures have been implemented, and that the relationship between measures and individual risks is evident. This way, an overview can be created that can help ensure that all identified risks have been assessed and managed by implementing appropriate security measures.

The Data Protection Agency further finds grounds to criticize that the Municipality of Copenhagen's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation.

Additionally, the Data Protection Agency recommends that the municipality, in connection with the planned update of the impact assessment, ensures that the information in the impact assessment is accurate in relation to the fact that AULA is also used in the municipality's daycare centers.

The Data Protection Agency also recommends that the Municipality of Copenhagen – possibly in dialogue with other municipalities, KOMBIT, and KL – clarifies the purpose of processing personal data in AULA in the municipality's impact assessment. In this context, it is also relevant to clarify in the impact assessment which document types Secure File Sharing is used for, and what types of personal data these document types typically contain.

4.4. General remarks from the Data Protection Agency

In system landscapes where multiple data controllers use the same systems and perform approximately...

the same processing of personal data, there can be a significant synergy in making joint assessments

regarding risk factors, potential impact assessments, and mitigating measures. The Data Protection Agency notes that it may be relevant to conduct a joint impact assessment if multiple data controllers are planning to implement a common IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that the same type of system is involved, the same processing activity of the same personal data, and that the processing activities entail similar high risks.

It is not crucial that there is full identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from one another. Otherwise, a supplement to the joint impact assessment must necessarily be prepared.

Thus, it is the opinion of the Data Protection Agency that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, the same types of personal data are processed, and the processing activities entail the same high risks.

It is the data controllers who specifically assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint impact assessment each bear the responsibility for conducting the impact assessment.

The Data Protection Agency believes that in relation to the municipalities' processing of personal data in AULA, the municipalities use the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities entail similar high risks. Furthermore, the system is provided by the same supplier. Thus, the municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

In associations and bodies that represent categories of data controllers, it may also be beneficial to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation to specify the application of the General Data Protection Regulation.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to assist in complying with data protection rules for the authorities that have subscribed to the code. This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that rest upon them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

In this context, the Data Protection Agency encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system for processing the same types of personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data (Data Protection Act).

[3] KL has described the User Portal Initiative on their website:

<https://www.kl.dk/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet>

[4] KOMBIT provides information about AULA on the website <https://aulainfo.dk/om-aula/>

[5] It appears from materials about the User Portal Initiative, available on KL's website: <https://www.kl.dk/media/jdeblg2i/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi-juni-2018.pdf>

[6] Guidelines for impact assessment regarding data protection (DPIA) and determining whether the processing "likely entails a high risk" under Regulation (EU) 2016/679, WP248 rev. 01, adopted on April 4, 2017, as last revised and adopted on October 4, 2017.

[7] According to recital 90, it states: "In such cases, the data controller should carry out an impact assessment regarding data protection prior to the processing to assess the specific likelihood and severity of the high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. The impact assessment should particularly include the measures, safeguards, and mechanisms that are planned to mitigate this risk, to ensure..." of the protection of personal data and the demonstration of compliance with this regulation."

[8] From recital 38, it is stated among other things: "Children should enjoy special protection of their personal data, as they are often less aware of the relevant risks, consequences, and safeguards and their rights regarding the processing of personal data. [...]"

[9] Reference is made to section III.D.b in the Article 29 Working Party's guidelines on data protection impact assessment (DPIA) and the determination of whether the processing "is likely to result in a high risk" in accordance with Regulation (EU) 2016/679 (WP 248)

[10] Reference is made to the Danish Data Protection Authority's guidance on impact assessment from March 2018.